Conducting risk-based analyses of zero-day vulnerabilities by evaluating CVEs, Indicators of Compromise (IOCs), and remediation measures, based on the NIST Cybersecurity Framework.

***Critical vulnerabilities and zero-day threats represent high-stakes challenges in cybersecurity**.*

Because zero-day threats are by definition unknown (no patch or signature exists), your focus must shift from preventing the initial exploitation to minimizing the blast radius and rapidly restoring operations

The best way to prepare for and solve critical vulnerabilities and zero-day events is to move beyond signature-based detection and adopt a proactive, resilience-oriented strategy grounded in a structured framework like the NIST Cybersecurity Framework (CSF) 2.0.

Feature	***Critical Vulnerability***	***Zero-Day Vulnerability***
Vendor Knowledge	*Known*	*Unknown*
Defense Strategy	*Patch Management*	*Behavioral Monitoring & Isolation*
Reaction Time	*Scheduled (Prioritized)*	*Immediate (Crisis Response)*
Primary Danger	*Delayed patching*	*Undetectable initial breach*



Fig.1: NIST Framework relation with Zero-Day Scenarios

Governance

Under the NIST model, governance is defined as the establishment, communication, and monitoring of an organization's cybersecurity risk management strategy, expectations, and policies. It is a core component of corporate governance, focused on risk governance and accountability.

The Govern function serves as the "overarching" structure for the other five functions: **Identify, Protect, Detect, Respond, and Recover**. While these latter functions involve the actual technical and operational execution of security, the Govern function dictates the strategy and priorities for those actions.

Implementation Tiers

To help organizations measure their governance maturity, NIST utilizes **Implementation Tiers** (ranging from Tier 1, "Partial," to Tier 4, "Adaptive"):

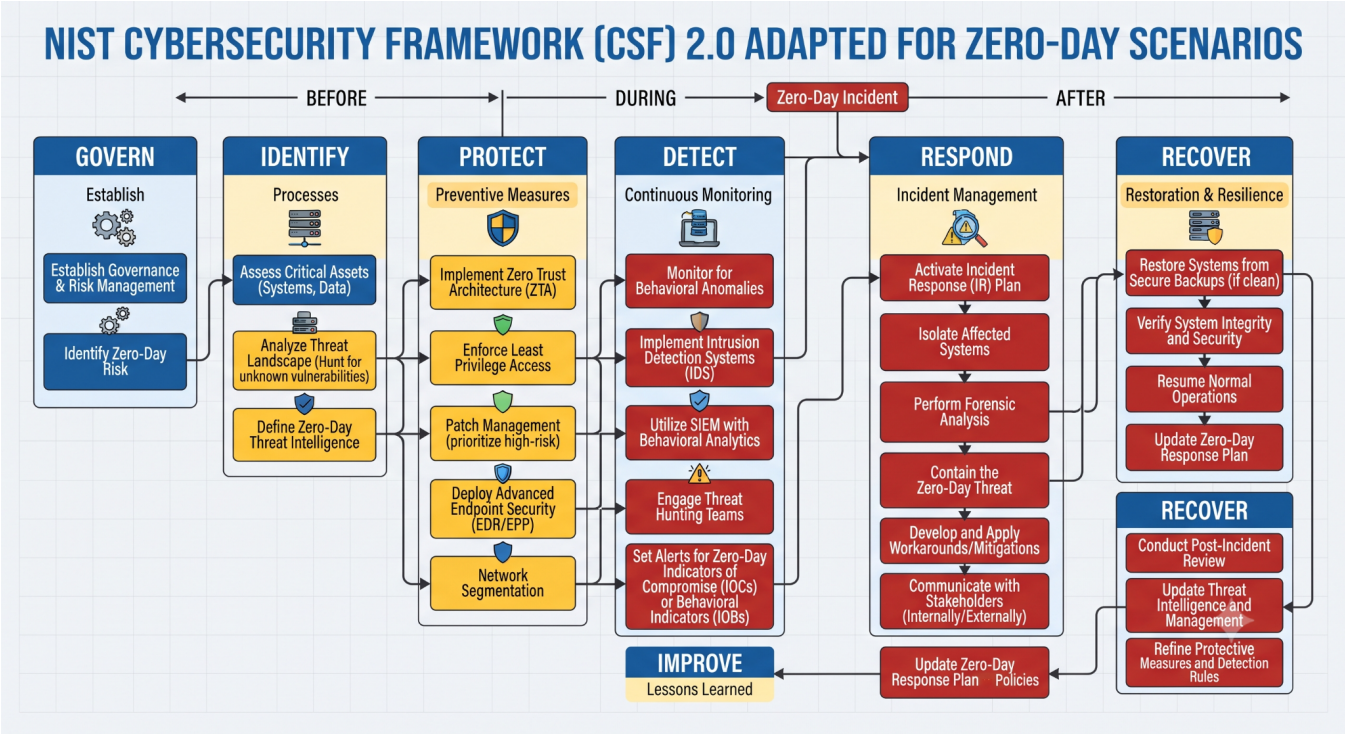


Fig.2: GOVERNANCE PHASE

- **Tier 1 (Partial):** Governance is informal or non-existent; cybersecurity activities are reactive.

  Tier 2 (Risk Informed): There is increased awareness, but governance is not yet consistent or organization-wide.

- **Tier 3 (Repeatable):** Governance is formalized, and management has implemented an organization-wide, repeatable risk management process.
- **Tier 4 (Adaptive):** Cybersecurity is fully integrated into organizational culture and business strategy. Governance is data-driven, predictive, and constantly evolving to address new threats.

General Concepts and Preparation Strategies

- NIST Incident Response Preparation: Detailed guidance on the importance of the preparation phase, including asset inventory and communication planning. |
- Zero-Day Lifecycle and Defence-in-Depth: An overview of how behavioural detection and layered security mitigate unknown threats.
- Zero-Trust Architecture: Modern security frameworks that focus on continuous verification to limit the movement of attackers.
- Incident Response Planning: Practical steps for developing a response plan that accounts for unpatched vulnerabilities

The preparation phase is often considered the most critical stage of incident response when dealing with zero-days scenarios. Because vulnerabilities in these scenarios are unknown and there are no available

patches, the preparation phase focuses on building a resilient environment that can detect unusual behaviour and contain an attack even when the specific threat is unknown. Preparation is not about stopping a threat but to build a “house” that can survive a break-in through a hidden door. It involves establishing the people, processes, and tools necessary to handle an emergency before it happens.

Preparation Strategies

Establish Governance & Risk Management

The Six Categories of the "Govern" Function

NIST CSF 2.0 organizes the Govern function into six distinct categories that provide a roadmap for leadership:

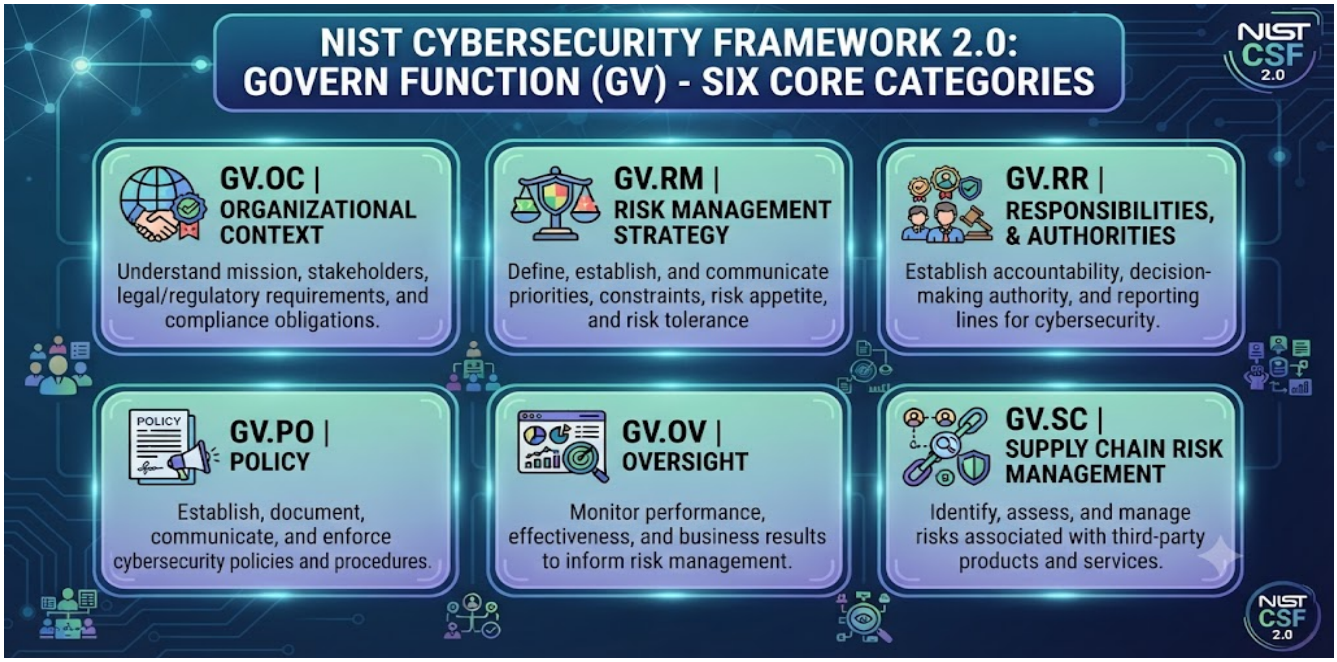


Fig.3: Govern Function- Six Core Categories

1. **Organizational Context (GV.OC):** Organizations must understand the circumstances, including mission, stakeholder expectations, and legal/regulatory requirements, that influence cybersecurity risk decisions.

   #### Key Components of GV.OC

   The category comprises five subcategories (GV.OC-01 through GV.OC-05) that guide an organization to:

- **Understand Mission Alignment:** Recognize the organizational mission and ensure it informs cybersecurity risk management decisions.
- **Identify Stakeholders:** Determine internal and external stakeholders and understand their specific needs and expectations regarding cybersecurity.
- **Acknowledge Obligations:** Identify and manage legal, regulatory, and contractual requirements, including privacy and civil liberties obligations.

- **Analyse Dependencies: * External Reliance:** Identify and communicate critical outcomes, capabilities, and services that the organization depends on from external parties.
    - **Stakeholder Reliance:** Determine and communicate critical objectives, capabilities, and services that stakeholders depend on or expect from the organization

2. **Risk Management Strategy (GV.RM):** This involves establishing and communicating the organization's risk appetite and risk tolerance, ensuring that risk management activities are prioritized according to business objectives.

   Risk Apetite is defined as the types and amount of risk an organization is willing to accept in pursuit of its value, mission, or vision and its purpose is to set the high-level boundaries for risk-taking in pursuit of organizational goals.

   Risk Tolerance provides the specific, measurable boundaries for that appetite. It defines the upper limit of risk the organization is willing to accept for specific assets, processes, or systems

Concept	Description	Implementation Example
Risk Appetite	The organization's broad posture.	"We have a low appetite for risks that could disrupt primary revenue services."
Risk Tolerance	Specific, measurable thresholds.	"Downtime for [System X] must not exceed 4 hours per quarter."

3. **Roles, Responsibilities, and Authorities (GV.RR):** Governance requires defining exactly who is accountable for cybersecurity decisions. It ensures that security roles are clear across the entire organization, from the board level to individual contributors.

   The primary goal of GV.RR is to establish clear accountability. Without defined roles and authorities, cybersecurity efforts often fail due to confusion, lack of budget, or "responsibility gaps" where critical security tasks fall through the cracks.

   The Core Components

   The category is structured to ensure that everyone from the Board of Directors to the system operators understands their contribution to the organization’s security posture.

4. **Policy (GV.PO):** This category focuses on creating and maintaining formal policies that reflect the organization’s cybersecurity goals, ensuring they are documented and understood.

Subcategory	Focus	Key Objective
GV.RR-01	Organizational Roles	Defining and communicating clear cybersecurity roles and responsibilities for all personnel.
GV.RR-02	Organizational Authorities	Ensuring that personnel have the explicit authority to carry out their assigned cybersecurity responsibilities.
GV.RR-03	Mission-Critical Assets	Designating specific individuals who are responsible for the security of mission-critical assets.

Policy translates the organization's high-level **Risk Appetite** and **Strategy** into actionable, repeatable, and enforceable documents. It bridges the gap between executive intent (the "what we want") and daily operations (the "how we do it").

The Core Components

The GV.PO category focuses on three essential elements of policy management

Subcategory	Focus	Core Objective
GV.PO-01	Development	Developing and establishing cybersecurity policies that align with the organizational mission and strategy.
GV.PO-02	Communication	Ensuring that cybersecurity policies are disseminated and understood by all personnel and relevant third parties.
GV.PO-03	Review and Update	Periodically reviewing and updating policies to ensure they remain relevant to the evolving threat landscape and organizational changes.

5. **Oversight (GV.OV):** Governance involves continuous monitoring of the cybersecurity strategy. It ensures that the organization's results are reviewed against its stated goals, providing the feedback loop necessary to adjust tactics.

   Oversight transforms cybersecurity from a static set of rules into a **dynamic, performance-driven program**. It moves the needle from "asserting" that security is working to "demonstrating" it through evidence, metrics, and continuous review

6. **Cybersecurity Supply Chain Risk Management (GV.SC):** Recognizing that risks often exist outside the perimeter, this category focuses on governing the risks associated with third-party service providers, suppliers, and external partners., it focuses on the systematic process of identifying, assessing, and managing risks throughout the technology product and service lifecycle, specifically regarding third-party relationships (suppliers, vendors, partners).

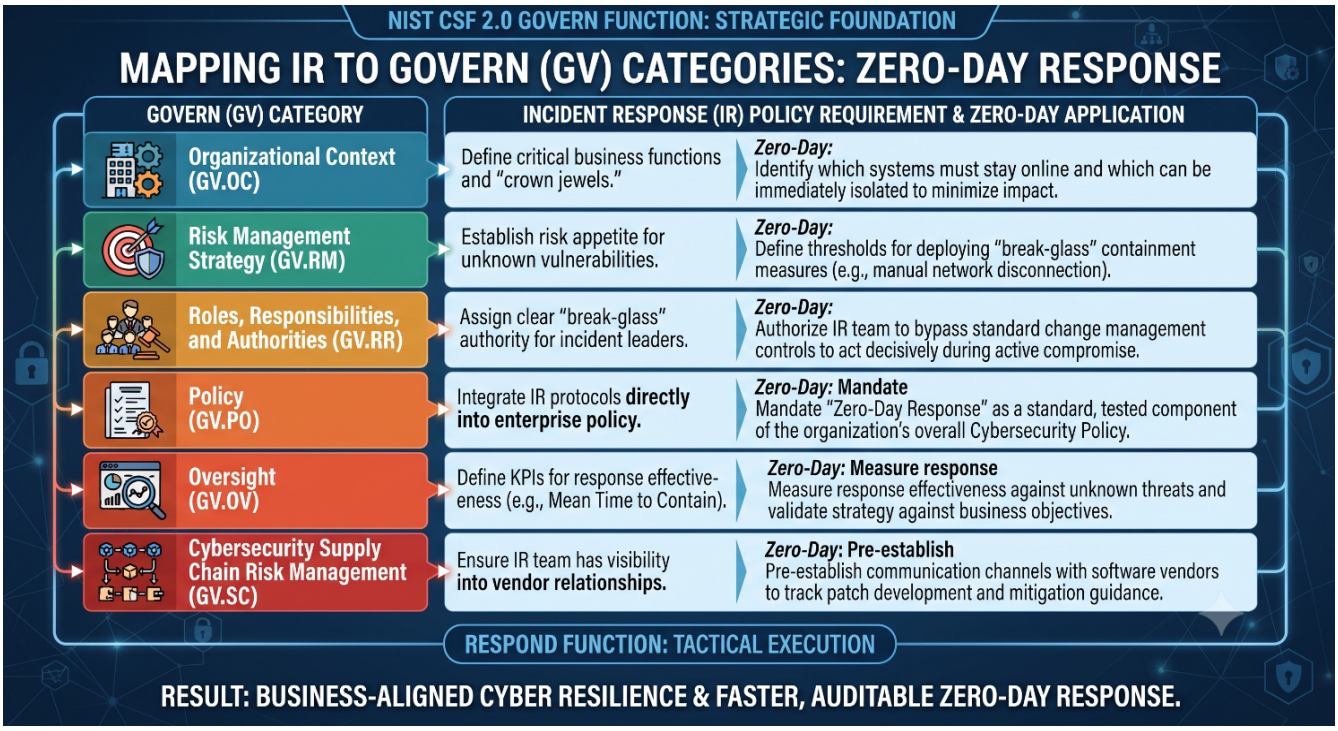


Fig.4: Mapping IR to Govern Categories

IDENTIFICATION PHASE

If Govern sets the strategy and "rules of the road," Identify provides the map of the environment where those rules are applied. Its core purpose is to develop an organizational understanding of your cybersecurity risk, ensuring you know exactly what you are protecting and why.

The Three Pillars of Identify

While previous versions of the framework included more categories here, CSF 2.0 has streamlined **Identify** to focus on three essential areas

Category	Focus	Core Objective
Asset Management (ID.AM)	Inventory & Classification	Knowing what you have (hardware, software, data, systems, and services) and prioritizing it based on business value.
Risk Assessment (ID.RA)	Threat & Vulnerability	Understanding the threats to those assets, the potential vulnerabilities, and the likelihood/impact of an incident.
Improvement (ID.IM)	Continuous Growth	Learning from your risk management activities to refine your program over time.

The Core Focus of ID.AM

The Identify function is the foundation for all subsequent actions (Govern, Protect, Detect, Respond, and Recover). ID.AM ensures that your cybersecurity strategy is based on accurate, real-time knowledge of your environment.

Subcategory	Requirement	Objective
ID.AM-01	Inventory of computing devices	Know exactly what hardware connects to your network.
ID.AM-02	Inventory of software platforms and applications	Understand the software stack, including OS and critical business apps.
ID.AM-03	Inventory of data and information	Classify data based on sensitivity and business value.

Subcategory	Requirement	Objective
ID.AM-04	Inventory of internal and external services	Identify dependencies on third-party cloud or managed services.
ID.AM-05	Identification of logical and physical dependencies	Map how assets, services, and data interact to support business functions.
ID.AM-06	Asset roles and responsibilities	Define who owns, manages, and is accountable for each asset.

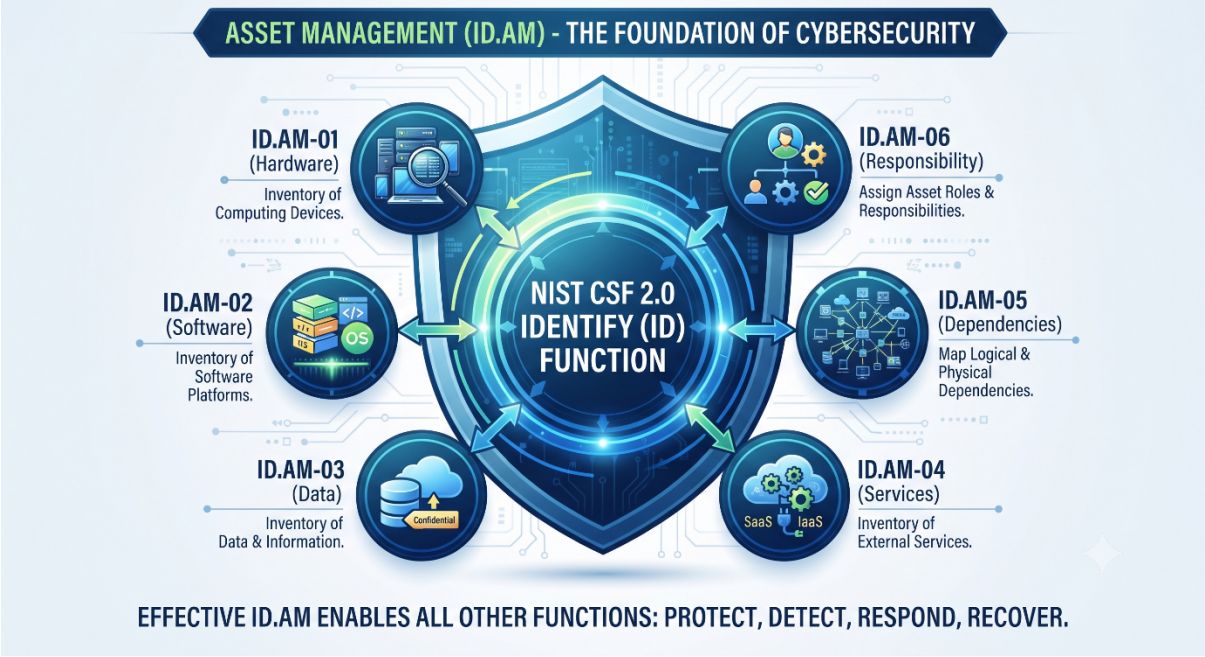


Fig.5: Asset Management (ID.AM)

Integrating with Other Functions

Asset Management is not an isolated activity; it feeds the rest of the NIST framework:

- **Govern:** Your risk appetite and tolerance are applied to specific asset classes (e.g., higher tolerance for non-critical assets; zero tolerance for critical customer data repositories).
- **Protect:** You cannot apply the correct safeguards (e.g., MFA, encryption) without knowing the type and sensitivity of the asset.
- **Recover:** During a recovery, the priority is determined by the criticality levels established in the Asset Management phase.

Risk Assessment (ID.RA)

The Core Focus of ID.RA

The primary goal of ID.RA is to move from a list of assets to an understanding of **cybersecurity risk** to operations, assets, and individuals. It translates technical data into business-relevant insights.

Subcategory	Focus	Key Activity
ID.RA-01	**Vulnerabilities**	Identify, validate, and record weaknesses in assets.
ID.RA-02	**Threat Intelligence**	Receive and integrate external threat data (TTPs, actors).
ID.RA-03	**Threats**	Record both internal and external threats.
ID.RA-04	**Impact & Likelihood**	Analyze the probability of exploitation and business impact.
ID.RA-05	**Inherent Risk**	Determine risk level to inform prioritization.
ID.RA-06	**Risk Response**	Choose, plan, and track the remediation strategy.
ID.RA-07	**Change Management**	Assess risk impact of configuration changes or exceptions.
ID.RA-08	**Vulnerability Disclosure**	Establish processes to handle external vulnerability reports.
ID.RA-09	**Acquisition Integrity**	Verify hardware/software integrity before use.
ID.RA-10	**Supplier Assessment**	Assess critical suppliers prior to engagement.

The "Risk Triangle": AM, RA, and RM

To implement ID.RA effectively, it must be tightly coupled with the other functions you've been focusing on:

1. **ID.AM (Asset Management):** Provides the "subject" of the assessment. You assess risks *to* the assets identified in your inventory.
2. **ID.RA (Risk Assessment):** Provides the "verdict." It calculates the impact and likelihood of a threat exploiting a vulnerability on those assets.
3. **GV.RM (Risk Management Strategy):** Provides the "threshold." Your **Risk Tolerance** (from the Govern function) is the benchmark used in ID.RA-06 to decide whether to *Accept, Mitigate, Transfer, or Avoid* the risk.

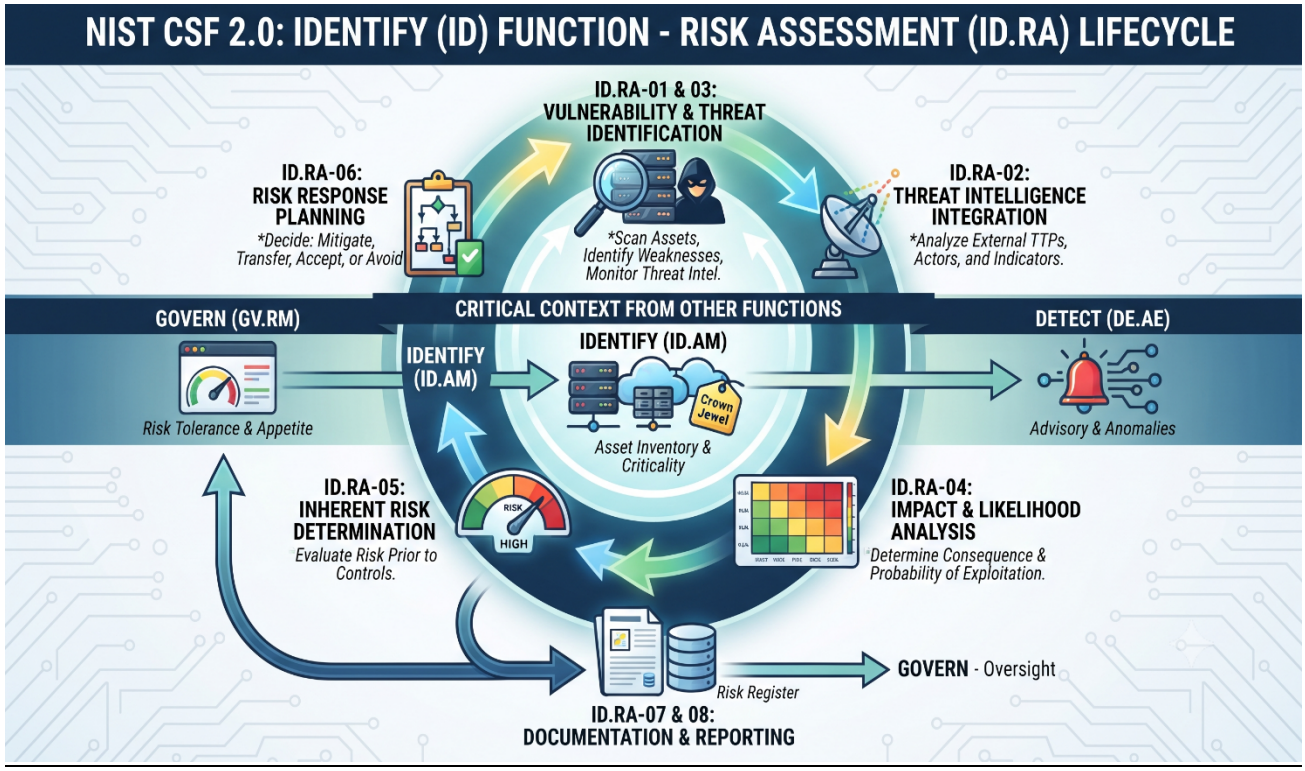


Fig.6: NIST CSF 2.0: Identify (ID) Function- Risk Assessment (ID.RA) Lifecycle

Improvement (ID.IM)

The primary outcome of ID.IM is the continuous refinement of the organization's cybersecurity program. It transitions the organization from a static security model to one of continuous improvement, ensuring that past experiences (both internal successes/failures and external industry trends) are actively used to strengthen defenses.

Key Subcategories of ID.IM

The Improvement category focuses on formalizing the process of learning and adapting:

- ID.IM-01: Improvement Planning: The organization communicates and implements improvements based on the results of previous activities and assessments. This ensures that findings from audits, exercises, and real-world incidents are not ignored but are turned into actionable projects.
- ID.IM-02: Lessons Learned: The organization identifies and documents lessons learned from internal and external activities, including cybersecurity incidents, to improve the cybersecurity program.
    - *Note:* This is where the post-incident analysis from the Recover function feeds back into the Identify function.

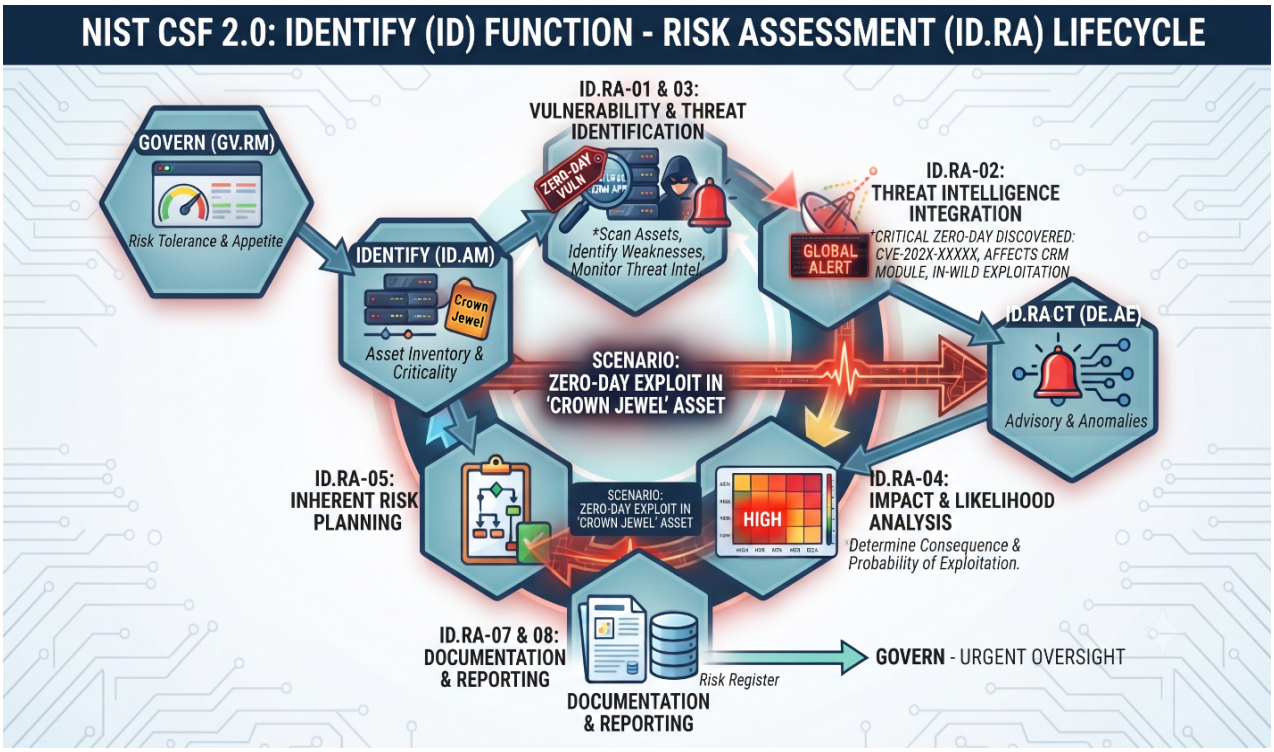


Fig.7: NIST CSF 2.0: Identify (ID) Function- Risk Assessment (ID.RA) Lifecycle

PROTECTION PHASE

The 72-hrs Response Timeline

Phase	Timeframe	Objective	Key Actions
1. Detect	Hour 0–6	Identify that an exploit exists	Correlate monitoring alerts, threat intelligence feeds, and vendor or CERT disclosures to confirm the vulnerability is real and relevant to your environment.
2. Contain	Hour 6-24	Stop the bleeding	Isolate affected systems, cut off attacker access paths, and apply emergency compensating controls (firewall rules, account lockdowns) while a permanent fix is prepared.
3. Remediate	Hour 24–48	Close the vulnerability	Test the vendor patch or a validated workaround in staging, then deploy it in waves across all affected systems, prioritizing internet-facing and high-value assets first.
4. Verify	Hour 48–72	Confirm the incident is closed	Scan for residual compromise, confirm full patch coverage, restore normal operations, and update policy based on lessons learned.

Why 72 Hours?

Seventy-two hours is a deliberately tight but achievable target. It's long enough to properly test a patch before mass deployment, but short enough to keep urgency high and stop response efforts from drifting. Many regulatory breach-notification windows (for example, 72-hour rules under GDPR-aligned frameworks) also anchor to this timeframe, so the blueprint doubles as a structure for meeting external reporting obligations.

Protection

Vendors typically need time to develop, test, and release a fix once a zero-day is disclosed. During that gap, the organization is exposed but not defenseless. Five categories of controls reduce that exposure:

- **EDR & Antivirus:** Endpoint Detection and Response (EDR) tools, paired with traditional antivirus, watch for the behavioral signatures of exploitation, like unusual process spawning, memory injection, privilege escalation (even when the specific exploit is unknown).
- **Firewalls, IDS & IPS:** Firewalls, intrusion detection systems (IDS), and intrusion prevention systems (IPS) can be tuned with emergency signatures or rules as soon as indicators of compromise are published, blocking known exploit traffic at the perimeter.
- **Network Segmentation:** Segmenting the network limits how far an attacker can move if a system is compromised. Isolating affected systems turns a potential organization-wide incident into a contained one.
- **Principle of Least Privilege:** Enforcing least privilege ensures that even a successfully exploited account or service has limited reach, reducing the blast radius of any single compromise.
- **Monitor Systems & Traffic:** Continuous monitoring of systems and network traffic is what makes early detection possible in the first place, and it remains essential throughout containment to confirm controls are holding.

DETECTION PHASE

Purpose of the Detection Phase

The Detect function of the NIST Cybersecurity Framework (CSF) 2.0 focuses on finding and analysing possible cybersecurity attacks in a timely manner. For a critical vulnerability or zero-day, detection cannot rely only on known signatures because the exploit may not yet have a patch or a published indicator of compromise. The objective is to identify abnormal activity early, validate whether it is malicious, and provide reliable information for containment and response.

1. Establish a baseline of normal activity

Monitor normal authentication patterns, endpoint processes, network connections, DNS requests, application behaviour, and data transfers. Baselines help analysts recognize unusual activity such as a service spawning an unexpected shell, a privileged account logging in at an unusual time, a process injecting code into another process, or a server suddenly communicating with an unfamiliar external host.

2. Collect and correlate security telemetry

Centralize logs from endpoints, servers, identity providers, firewalls, IDS/IPS, DNS, VPNs, cloud platforms, and critical applications in a SIEM. Correlate events across sources rather than treating each alert in isolation. EDR telemetry can reveal suspicious process trees, while network monitoring can show command-and-control traffic or lateral movement. Ensure clocks are synchronized and logging is enabled on critical assets.

3. Use behavioral detection and threat intelligence

Use anomaly detection, endpoint behavior analytics, network intrusion detection, and rules based on attacker techniques. Enrich alerts with current threat intelligence, indicators of compromise (IOCs), vulnerability advisories, CVE/CVSS information, and MITRE ATT&CK techniques where applicable. Intelligence can improve detection, but the absence of a known IOC does not prove that a system is safe.

4. Triage and validate alerts

The SOC analyst reviews alert severity, affected assets, account privileges, event timelines, and supporting evidence. Determine whether the activity is a true positive, false positive, or requires further investigation. Priorities alerts involving internet-facing systems, critical business services, privileged accounts, suspicious persistence, exploitation indicators, or unexpected outbound traffic. Preserve relevant logs and evidence before making changes that could destroy it.

5. Confirm scope and escalate

Identify potentially affected hosts, users, applications, data, and connected systems. Look for related activity across the environment and check whether the vulnerability is present on exposed assets. Escalate credible exploitation or unexplained high-impact behavior to the incident-response lead immediately, following the organization's severity matrix and escalation path.

Detection outputs

Record the alert source, timestamps, affected assets, observed behavior, relevant IOCs, vulnerability details, confidence level, severity, actions already taken, and recommended next steps. The detection record should support a clear decision about whether to declare an incident and begin response activities. Continue monitoring during containment to determine whether the attacker remains active.

Key principle: for a zero-day, behavior and context may provide the strongest early warning. Detection should be continuous, correlated across multiple data sources, and connected to a documented escalation process.

RESPONSE PHASE

Purpose of the Response Phase

The Respond function of NIST CSF 2.0 coordinates action after a cybersecurity incident is detected. For a critical vulnerability or suspected zero-day, the priorities are to limit harm, understand the incident, remove unauthorised access, communicate with the right stakeholders, and reduce the chance of further exploitation. Response decisions should follow the organisation's incident-response plan, risk tolerance, and established authority levels.

1. Declare and coordinate the incident

The incident lead validates the available evidence, assigns a severity level, activates the appropriate response team, and opens an incident record. Define responsibilities for SOC analysts, IT operations, vulnerability management, legal/privacy teams, communications, business owners, and external providers. Establish a secure communication channel in case normal email or collaboration systems are compromised.

2. Contain the threat

Limit the attacker's ability to continue operating. Depending on the evidence and business impact, isolate affected endpoints, disable compromised accounts, revoke suspicious sessions and tokens, block malicious domains or IP addresses, restrict vulnerable services, and apply temporary firewall or access-control rules. For a zero-day without a patch, use compensating controls such as disabling the affected feature, restricting exposure, or placing the system behind additional filtering. Coordinate containment with system owners to avoid unnecessary disruption and preserve evidence where possible.

3. Investigate the scope and impact

Build a timeline from SIEM, EDR, identity, application, and network logs. Determine the likely initial access vector, affected systems and accounts, attacker actions, possible persistence, lateral movement, data access or exfiltration, and whether the vulnerability was exploited. Collect and protect forensic evidence, record decisions and timestamps, and update the incident hypothesis as new facts emerge. Do not assume that one affected host represents the full scope.

4. Eradicate and remediate

Remove identified malicious files, persistence mechanisms, unauthorised accounts, and attacker access. Apply a vendor patch when available and validated, or deploy a trusted workaround while waiting for a permanent fix. Test changes in a controlled environment when feasible, prioritise internet-facing and business-critical assets, and track remediation coverage. If compromise cannot be confidently removed, rebuild affected systems from trusted sources and rotate credentials or secrets that may have been exposed.

5. Communicate and meet reporting obligations

Provide timely, factual updates to leadership, IT teams, affected business owners, and other authorised stakeholders. Legal and privacy specialists should assess contractual, regulatory, and breach-

notification obligations. Share indicators and technical details with vendors, service providers, or relevant authorities when appropriate and authorised. Keep communications consistent, document what is known and unknown, and avoid unsupported conclusions.

6. Verify containment and hand over to recovery

Confirm that suspicious activity has stopped, attacker access paths are blocked, and the immediate risk is controlled. Increase monitoring for repeated exploitation attempts and signs of persistence. Document outstanding risks, temporary controls, patch status, affected assets, and criteria for safe restoration. Hand these findings to the Recovery phase so systems are returned to service only after appropriate checks.

Response evidence and success measures

Maintain an incident timeline, decisions and approvals, evidence references, containment actions, communication records, remediation status, and unresolved risks. Review time to acknowledge, time to contain, time to remediate, and the scope of affected assets. After the incident, conduct a lessons-learned review and feed improvements into detection rules, playbooks, asset inventories, and risk assessments.

Key principle: act quickly but deliberately. Containment reduces the blast radius; evidence-based investigation and verified remediation reduce the likelihood of recurrence.

RECOVERY PHASE

When a cyberattack hits, **recovery** is the stage where an organization gets its systems and services working safely and normally. In our investigation we used the **NIST Cybersecurity Framework** (a widely used, free U.S. government playbook for managing cyber risk) approach.

What "Recovery" means

In the framework, Recovery (the **RECOVER** function) is simply this: **restore the assets and operations that the incident affected.** The goal is to bring things back to normal, safely and in good timing, while keeping people informed. It has two parts: getting systems back up (**Incident Recovery Plan Execution, RC.RP**) and keeping everyone informed (**Incident Recovery Communication, RC.CO**).

The recovery steps, in order

Recovery is a careful, verified sequence:

1. Execute the plan. Start the recovery plan you prepared in advance (Eg, Playbooks, Manuals, etc.).
2. Prioritize. Decide what to restore first, based on what matters most.
3. Verify backups. Check that your backups (saved copies of data) are clean and trustworthy before using them.
4. Restore and confirm. Restore the systems and confirm they are truly back to normal.
5. Set new norms. Set new, safer "normal" rules for operating after the incident.
6. Close it out. Officially declare recovery finished, but only when it meets agreed criteria and all the important points of the attack have been documented.

The golden rule: trust, but verify. Check backups before you use them, and check restored systems afterward.

Why a zero-day makes recovery harder

A zero-day breaks three things we normally take for granted:

- No fix exists yet. You might restore a system only to find it is still open to the same attack. Until the vendor releases a patch, you must add temporary protections (“compensating controls”).
- Your backups might already be infected. Attackers often get in well before anyone notices, so even saved copies can hide their tools. That is why you verify backups first.
- The attacker might survive the cleanup. Some malicious code can outlast a restart, or even a full factory reset.

Real example: In 2025, for a set of zero-day flaws in Cisco security devices, the U.S. cyber agency **CISA** warned that rebooting was not enough and required a **physical hard reset**, because the malware had buried itself in the device's read-only memory. In the worst cases, “recovery” means rebuilding from scratch or even replacing hardware.

Trusted tools that help

- MITRE D3FEND: Its “Restore” step describes how to return systems to a known-good state.
- CVSS 4.0: Version 4 adds a “Recovery” label that flags whether a system can bounce back automatically, needs a person to fix it, or is beyond repair.
- CISA: This U.S. Agency offers free help: an “Eviction Strategies” tool for removing attackers, a public list of vulnerabilities known to be under active attack (the KEV catalog), and emergency directives that set deadlines to act while no patch exists.
- NIST SP 800-184: a dedicated guide on cyber-event recovery (how to plan it, practice it, and measure it).

Communicate and confirm

Recovery isn't done until it is both **verified** and **communicated**. Keep people updated (customers, partners, regulators) and share public updates through approved channels. Declare “all clear” only when it meets agreed criteria. With a zero-day, whose full reach may be unknown, it is wise not to rush that call. Finally, turn the experience into lessons that strengthen future defenses.

Bibliography

1. https://docs.fortinet.com/document/fortigate/7.4.2/ngfw-atp-concept-guide/868490/statistical-anomaly-based-detection
2. https://fastercapital.com/content/Anomaly-Detection--Detecting-Suspicious-Behavior-with-IPS.html
3. https://en.wikipedia.org/wiki/Anomaly-based_intrusion_detection_system
4. https://letsdefend.io/blog/nist-incident-response-preparation-phase
5. https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-184.pdf
6. https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-61r2.pdf
7. https://doi.org/10.6028/NIST.SP.800-61r3
8. https://doi.org/10.6028/NIST.CSWP.29
9. https://baconunlimited.com/zero-day-vulnerability-response-plan/
10. https://www.taylorwessing.com/de/global-data-hub/2025/digital-resilience-and-cyber-security/gdh---monitoring-preparedness-and-governance-under-eu-cyber-security-legislation
11. https://safe.security/resources/insights/nist-cybersecurity-framework/
12. https://en.wikipedia.org/wiki/NIST_Cybersecurity_Framework#:~:text=Organizational%20Context%20(GV.,Risk%20Management%20Strategy%20(GV.
13. https://www.mimecast.com/content/cybersecurity-governance/#:~:text=By%20defining%20clear%20governance%20policies,a%20robust%20cybersecurity%20governance%20program.
14. https://www.vectra.ai/topics/zero-day#:~:text=threat%20in%20advance.-,What%20is%20a%20zero%2Dday%20vulnerability%3F,before%20attackers%20can%20exploit%20it.
15. https://www.manageengine.com/compliance-manager/nist-csf-compliance/nist-csf-respond-function.html#:~:text=Activities%20related%20to%20incident%20management,event%20analysis%20and%20lessons%20learned.
16. https://safe.security/resources/insights/nist-cybersecurity-framework/
17. https://csf.tools/reference/nist-cybersecurity-framework/v2-0/gv/#:~:text=The%20organization's%20priorities%2C%20constraints%2C%20risk,%3A%20Roles%2C%20Responsibilities%2C%20And%20Authorities
18. https://csrc.nist.rip/Projects/Cybersecurity-Framework/Filters#/csf/filters
19. https://www.paloaltonetworks.com/cyberpedia/what-is-nist-csf#:~:text=2.0%20Core%20Functions-,Function,Secure%20critical%20assets%20and%20infrastructure
20. https://csrc.nist.gov/glossary/term/zero_day_attack
21. Dempsey, K., et al. (n.d.). Automation Support for Security Control Assessments (NISTIR 8011, Vol. 3). National Institute of Standards and Technology.
22. https://www.cisa.gov/known-exploited-vulnerabilities-catalog
23. https://cloud.google.com/blog/topics/threat-intelligence/2024-zero-day-trends
24. https://www.cisa.gov/known-exploited-vulnerabilities-catalog
25. https://www.cisa.gov/news-events/directives/ed-25-03

26. https://www.cisa.gov/resources-tools/resources/eviction-strategies-tool
27. https://d3fend.mitre.org/tactic/d3f:Restore/
28. https://www.first.org/cvss/v4.0/specification-document
29. https://doi.org/10.6028/NIST.SP.800-61r3
30. https://doi.org/10.6028/NIST.SP.800-184
31. https://doi.org/10.6028/NIST.CSWP.29